BÁO CÁO THUYẾT MINH DỰ ÁN KHOA HỌC KỸ THUẬT STEM

HỆ THỐNG NHÀ THÔNG MINH ZENHOME (PHIÊN BẢN HIỆN TẠI)

Dự án: ZenHome - Nền tảng Nhà Thông Minh Đa Kết Nối An Toàn & Bảo Mật

Lĩnh vực: Hệ thống nhúng, Phần mềm hệ thống & Internet vạn vật (IoT)

Phiên bản hệ thống hiện tại: Mobile App `v1.8.1` *(Build* `186`*)* | *Backend Server* `v2.5.0` | *ESP32 Firmware* `v2.5.0`

Mã nguồn dự án: [D:\STEM_2026-2027](file:///d:/STEM_2026-2027)

MỤC LỤC TỔNG QUAN

• [PHẦN I: NỘI DUNG CƠ BẢN (DÀNH CHO BAN GIÁM KHẢO KHÔNG CHUYÊN VÀ HỌC SINH)](#phần-i-nội-dung-cơ-bản-dành-cho-ban-giám-khảo-không-chuyên-và-học-sinh)

• [1. Giới thiệu dự án, bối cảnh thực tiễn và tính cấp thiết](#1-giới-thiệu-dự-án-bối-cảnh-thực-tiễn-và-tính-cấp-thiết)

• [2. Kiến trúc tổng thể và nguyên lý hoạt động của ZenHome](#2-kiến-trúc-tổng-thể-và-nguyên-lý-hoạt-động-của-zenhome)

• [3. Cơ chế điều khiển lai thông minh (Hybrid Control): Không lo mất mạng](#3-cơ-chế-điều-khiển-lai-thông-minh-hybrid-control-không-lo-mất-mạng)

• [4. Cơ chế an toàn điện và phòng chống cháy nổ (Power-On Safety)](#4-cơ-chế-an-toàn-điện-và-phòng-chống-cháy-nổ-power-on-safety)

• [5. Giám sát vi khí hậu và tự động hóa không gian sống](#5-giám-sát-vi-khí-hậu-và-tự-động-hóa-không-gian-sống)

• [6. Đánh giá tính khả thi, giá thành và giá trị giáo dục STEM](#6-đánh-giá-tính-khả-thi-giá-thành-và-giá-trị-giáo-dục-stem)

• [PHẦN II: NỘI DUNG NÂNG CAO (DÀNH CHO CHUYÊN GIA CÔNG NGHỆ VÀ LẬP TRÌNH)](#phần-ii-nội-dung-nâng-cao-dành-cho-chuyên-gia-công-nghệ-và-lập-trình)

• [1. Phân tích tầng nhúng vi điều khiển & Kiến trúc FreeRTOS đa nhân (ESP32)](#1-phân-tích-tầng-nhúng-vi-điều-khiển--kiến-trúc-freertos-đa-nhân-esp32)

• [2. Tầng mật mã học đa lớp: Thỏa thuận khóa DH-1536, HMAC-SHA256 & Chống phát lại](#2-tầng-mật-mã-học-đa-lớp-thỏa-thuận-khóa-dh-1536-hmac-sha256--chống-phát-lại)

• [3. Cơ chế phân quyền phần cứng RBAC và Hệ thống cạm bẫy Honey-Tokens](#3-cơ-chế-phân-quyền-phần-cứng-rbac-và-hệ-thống-cạm-bẫy-honey-tokens)

• [4. Kiến trúc máy chủ trung tâm & Thuật toán chống tràn hàng đợi bộ nhớ RAM](#4-kiến-trúc-máy-chủ-trung-tâm--thuật-toán-chống-tràn-hàng-đợi-bộ-nhớ-ram)

• [5. Cơ chế cập nhật không dây OTA & Quy trình xuất bản khi triển khai Tên miền](#5-cơ-chế-cập-nhật-không-dây-ota--quy-trình-xuất-bản-khi-triển-khai-tên-miền)

• [6. Phân tích tầng ứng dụng Flutter & Bộ quy tắc bảo mật Cloud Firestore](#6-phân-tích-tầng-ứng-dụng-flutter--bộ-quy-tắc-bảo-mật-cloud-firestore)

• [7. Tổng kết khoa học, tính sáng tạo và tiềm năng mở rộng](#7-tổng-kết-khoa-học-tính-sáng-tạo-và-tiềm-năng-mở-rộng)

PHẦN I: NỘI DUNG CƠ BẢN

(Dành cho Ban Giám Khảo không chuyên môn, Giáo viên và Học sinh)

1. Giới thiệu dự án, bối cảnh thực tiễn và tính cấp thiết

Trong kỷ nguyên chuyển đổi số và phát triển đô thị thông minh, nhu cầu tự động hóa và quản lý các thiết bị điện trong gia đình (Smart Home) đang ngày một tăng cao. Tuy nhiên, các giải pháp thương mại hiện nay thường gặp phải 3 rào cản lớn:

1. Phụ thuộc hoàn toàn vào đường truyền Internet: Khi nhà mạng gặp sự cố hoặc mất tín hiệu cáp quang, toàn bộ hệ thống Smart Home thương mại thường bị "tê liệt", người dùng không thể bật tắt đèn, quạt hay kiểm tra trạng thái nhà cửa ngay cả khi đang đứng trong phòng khách.
2. Nguy cơ mất an toàn phòng cháy chữa cháy sau sự cố điện lưới: Tại Việt Nam, hiện tượng cúp điện đột ngột và sau đó có điện trở lại xảy ra khá phổ biến. Khi có điện lại, việc các thiết bị công suất lớn sinh nhiệt (như bàn là, bếp điện, bình nóng lạnh, ấm siêu tốc) tự động bật lại do lưu trạng thái cũ có thể gây chập cháy hỏa hoạn nghiêm trọng nếu không có người ở nhà.
3. Chi phí đắt đỏ và tính bảo mật riêng tư kém: Nhiều thiết bị giá rẻ trên thị trường gửi dữ liệu máy chủ không rõ nguồn gốc ở nước ngoài, dễ bị rò rỉ dữ liệu sinh hoạt của gia đình.

Xuất phát từ thực tiễn trên, dự án ZenHome được nghiên cứu và phát triển hoàn toàn bởi học sinh với mục tiêu: Xây dựng một hệ sinh thái Nhà Thông Minh chi phí thấp, làm chủ 100% công nghệ, hoạt động theo triết lý Ưu tiên mạng nội bộ (Local-First) kết hợp Đám mây linh hoạt (Hybrid Cloud), bảo vệ tính mạng và tài sản gia đình thông qua cơ chế An toàn chống cháy nổ khi khôi phục nguồn điện.

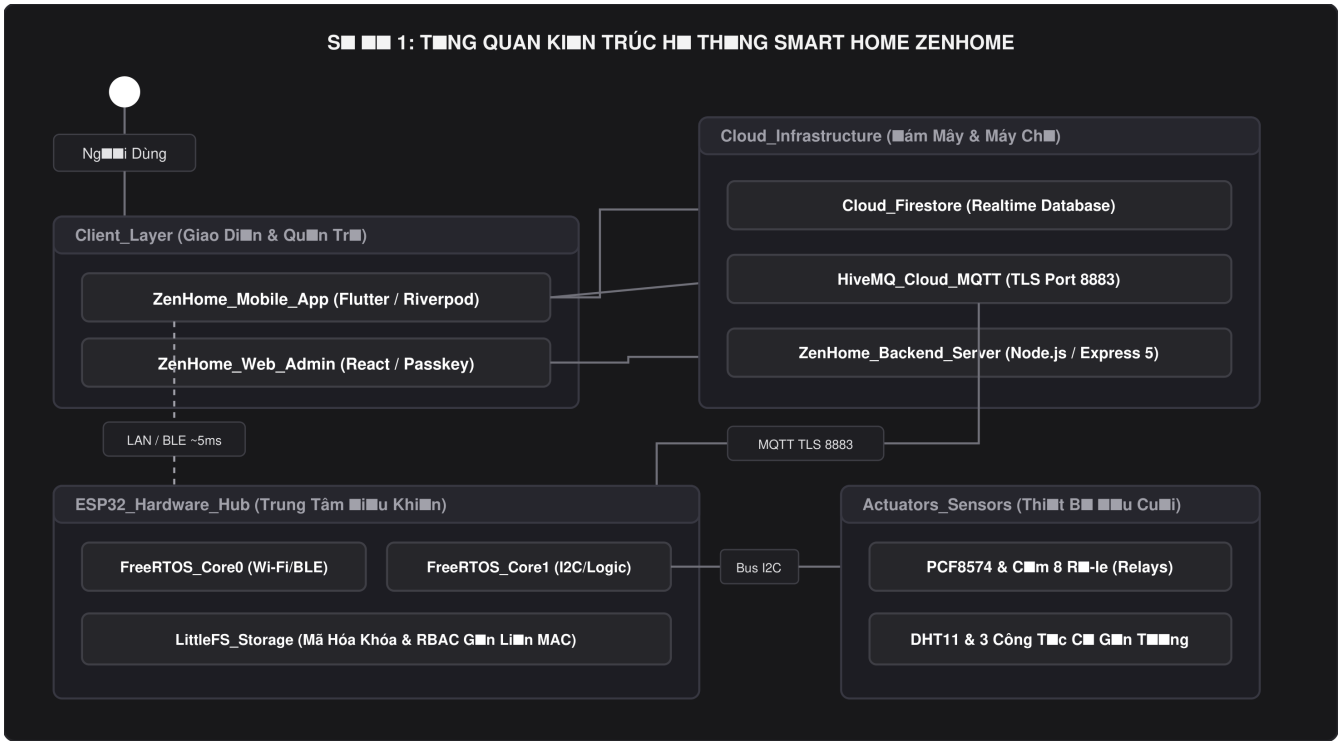
2. Kiến trúc tổng thể và nguyên lý hoạt động của ZenHome

Hệ sinh thái ZenHome được thiết kế đồng bộ từ Phần cứng đến Phần mềm, gồm 3 khối chính:

• Thiết bị trung tâm (ZenHome Hub - ESP32): Trái tim của ngôi nhà, kết nối trực tiếp với 8 kênh rơ-le để đóng ngắt các thiết bị điện 220V (bóng đèn, quạt máy, máy bơm, ổ cắm), tích hợp cảm biến nhiệt độ - độ ẩm DHT11 và 3 công tắc cơ trên tường.

• Ứng dụng di động (ZenHome App - Flutter): Cài đặt trên điện thoại thông minh (Android/iOS), cung cấp giao diện trực quan, cho phép người dùng điều khiển phòng ốc, hẹn giờ, lập lịch tự động và nhận thông báo khẩn cấp.

• Hệ thống Đám mây & Máy chủ dự phòng (Cloud & Server): Sử dụng Google Cloud Firestore để đồng bộ dữ liệu thời gian thực, HiveMQ Cloud TLS để điều khiển từ xa qua mạng di động (4G/5G), và máy chủ Node.js để tự động gửi thông báo đẩy (Push Notification) đến điện thoại.



▲ *Sơ đồ 1: Tổng quan kiến trúc hệ thống Smart Home ZenHome*

3. Cơ chế điều khiển lai thông minh (Hybrid Control): Không lo mất mạng

Một trong những sáng tạo nổi bật nhất của ZenHome là cơ chế Điều khiển Lai 3 Cấp (Hybrid 3-Tier Fallback). Người dùng không cần phải quan tâm mình đang kết nối bằng cách nào, ứng dụng sẽ tự động chọn con đường nhanh nhất và ổn định nhất:

1. Cấp 1 - Mạng Wi-Fi nội bộ (Local LAN - Ưu tiên hàng đầu):

• Khi điện thoại và Hub cùng kết nối vào bộ phát Wi-Fi gia đình, ứng dụng sẽ bắn lệnh trực tiếp tới Hub qua mạng LAN.

• Tốc độ: Phản hồi tức thì chỉ mất khoảng 5 mili-giây (nhanh gấp 30-50 lần so với việc phải gửi tín hiệu lên vệ tinh/server rồi mới vòng về nhà).

• Đặc điểm: Không cần Internet, đường truyền cáp quang quốc tế bị đứt thì trong nhà vẫn bật tắt đèn mượt mà.

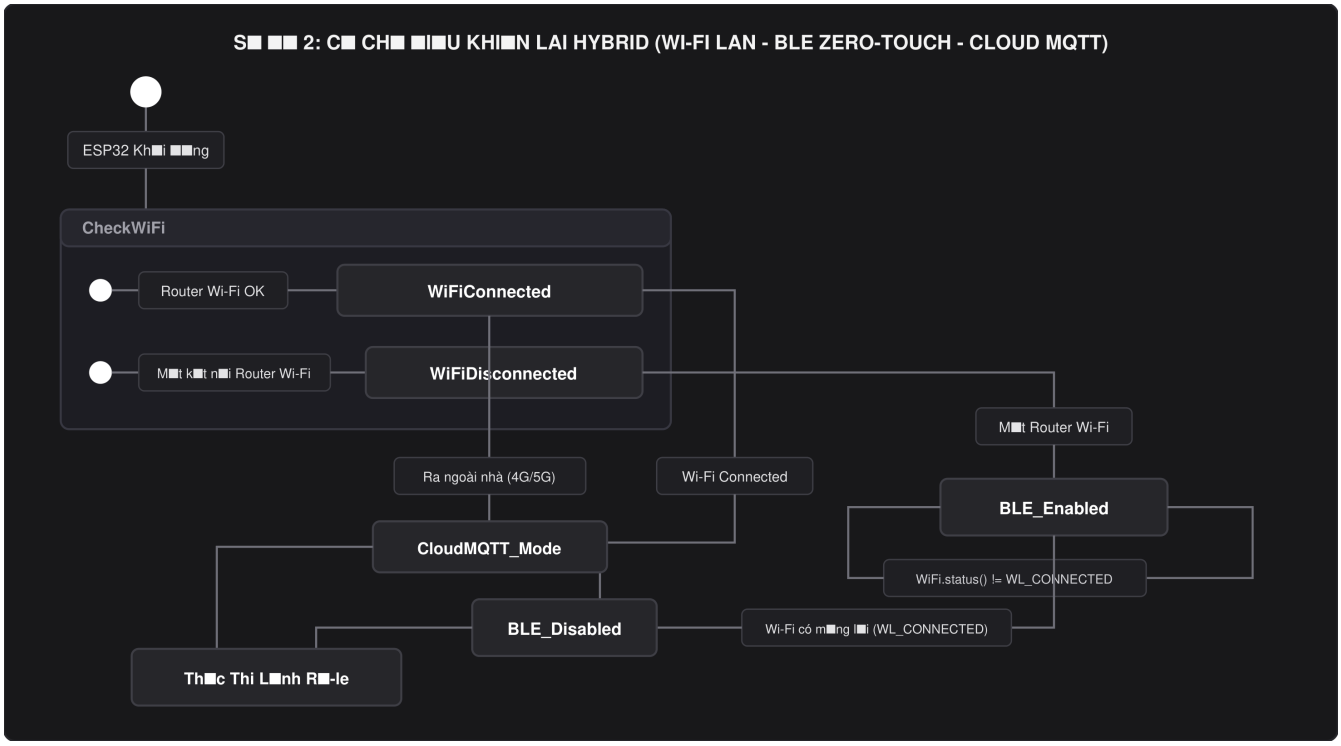
2. Cấp 2 - Sóng Bluetooth năng lượng thấp (BLE Zero-Touch - Dự phòng khẩn cấp):

• Khi bộ phát Wi-Fi (Router) gia đình bị hỏng hoặc mất nguồn, điện thoại không thể vào Wi-Fi.

• Ngay lập tức, Hub tự động kích hoạt sóng Bluetooth LE. Ứng dụng điện thoại tự nhận diện sóng Bluetooth của ngôi nhà mà người dùng không cần ghép đôi thủ công phức tạp. Lệnh điều khiển được truyền trực tiếp qua sóng không dây tầm gần.

3. Cấp 3 - Đám mây bảo mật (Fallback Cloud MQTT - Khi ra khỏi nhà):

• Khi người dùng đi làm, đi học hoặc du lịch cách xa hàng trăm cây số, điện thoại dùng mạng 4G/5G sẽ gửi lệnh mã hóa TLS qua máy chủ đám mây MQTT để điều khiển thiết bị ở nhà mọi lúc mọi nơi.



▲ *Sơ đồ 2: Cơ chế điều khiển lai Hybrid 3 cấp*

4. Cơ chế an toàn điện và phòng chống cháy nổ (Power-On Safety)

Các hệ thống nhà thông minh thông thường trên thị trường thường có hai cách xử lý sau khi có điện lại:

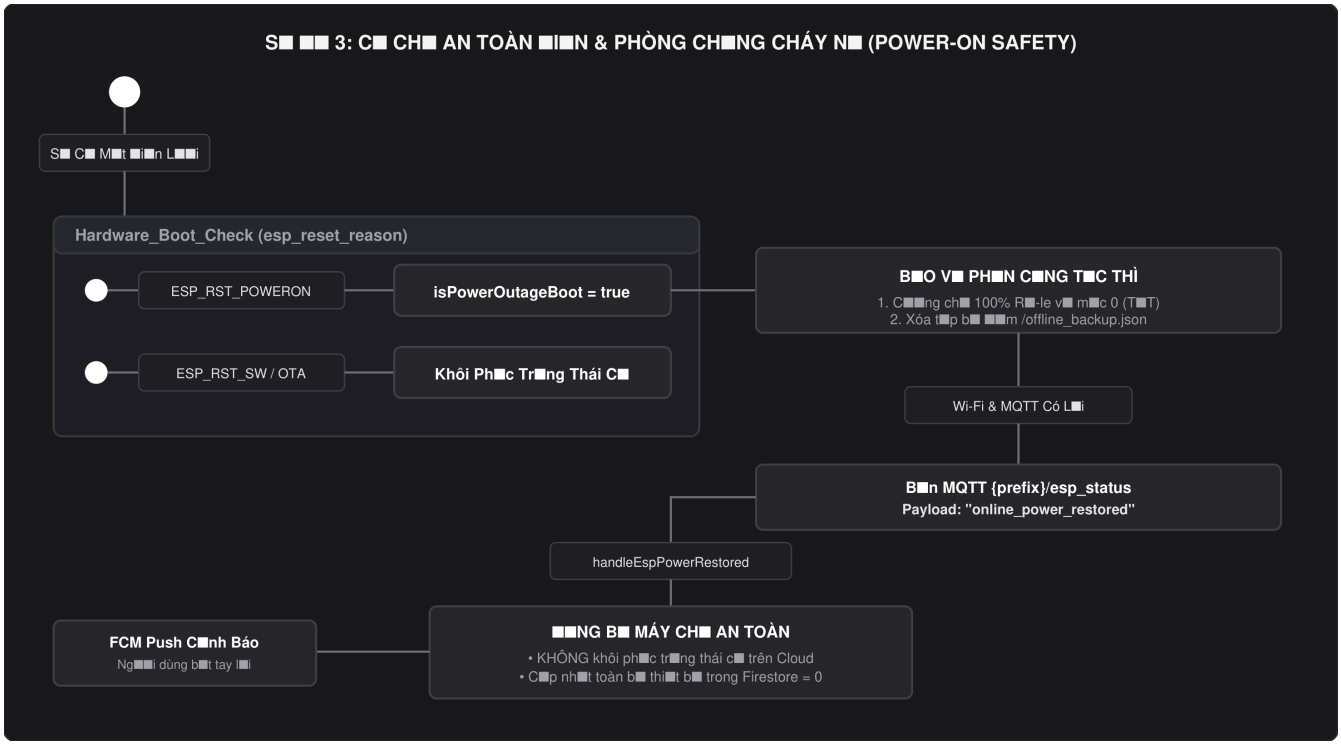
- Cách 1: Khôi phục lại trạng thái cũ trước khi mất điện. Điều này cực kỳ nguy hiểm nếu trước đó chủ nhà đang là quần áo, bật bếp điện rồi mất điện và vội đi làm. Khi có điện lại, thiết bị tự bật nóng liên tục trong nhà vắng người, gây cháy nổ.
- Cách 2: Máy chủ tự động đồng bộ đẩy trạng thái xuống. Điều này gây xung đột giữa phần cứng và phần mềm, rơ-le nhảy lách cách bất thường.

Giải pháp đột phá của ZenHome:

Khi có điện trở lại, mạch phần cứng ESP32 lập tức phát hiện sự cố cấp nguồn (`ESP_RST_POWERON`). Mạch sẽ chủ động cưỡng chế ngắt toàn bộ 100% rơ-le về trạng thái TẮT (OFF) trong vòng 5 mili-giây đầu tiên, đồng thời xóa sạch bộ đệm ghi nhớ trạng thái cũ.

Sau khi kết nối mạng được thiết lập lại, Hub phát tín hiệu đặc tả `"online_power_restored"` lên máy chủ. Máy chủ nhận diện đây là sự kiện khôi phục sau mất điện nên tuyệt đối không bật lại thiết bị, đồng thời bắn thông báo khẩn cấp đến điện thoại người dùng:

> *"Cảnh báo an toàn: Điện lưới gia đình đã có trở lại. Để phòng chống cháy nổ, toàn bộ thiết bị sinh nhiệt và tải điện đã được ngắt an toàn. Vui lòng kiểm tra thực tế và bật lại khi cần thiết."*



▲ *Sơ đồ 3: Cơ chế an toàn điện và phòng chống cháy nổ*

5. Giám sát vi khí hậu và tự động hóa không gian sống

Bên cạnh việc điều khiển thủ công, ZenHome nâng cao chất lượng đời sống gia đình thông qua các tiện ích:

• Giám sát vi khí hậu thời gian thực: Cảm biến DHT11 đo chính xác nhiệt độ và độ ẩm phòng. Dữ liệu được vẽ thành đồ thị trực quan trên ứng dụng di động.

• Tự động hóa thông minh (Local Rule Engine): Người dùng có thể cài đặt: "Nếu nhiệt độ phòng vượt quá 32°C thì tự động bật quạt máy", hoặc "Sau khi bật máy bơm nước 15 phút thì tự động tắt để chống tràn bồn".

• Ưu tiên quyền con người (Manual Override Holdoff): Nếu luật tự động đang tắt đèn nhưng người dùng bấm công tắc cơ trên tường để bật đèn, hệ thống sẽ ưu tiên thao tác của con người và tạm khóa luật tự động trong 30 phút, tránh hiện tượng máy móc tự ý tắt đèn khi người dùng đang học bài.

• Hẹn giờ và ngữ cảnh một chạm: Thiết lập các kịch bản tiện ích như "Rời khỏi nhà" (ngắt hết thiết bị điện), "Đi ngủ" (tắt đèn chính, bật đèn ngủ và quạt mức êm).

6. Đánh giá tính khả thi, giá thành và giá trị giáo dục STEM

• Chi phí chế tạo siêu tiết kiệm:

• Vi điều khiển ESP32: ~90.000 VNĐ

• Mạch rơ-le 8 kênh cách ly quang: ~80.000 VNĐ

• IC mở rộng I2C PCF8574: ~20.000 VNĐ

• Cảm biến nhiệt độ DHT11: ~18.000 VNĐ

• Tổng chi phí phần cứng hoàn thiện một bộ điều khiển 8 thiết bị: ~250.000 VNĐ (chỉ bằng 1/10 đến 1/15 so với các bộ điều khiển thương mại tương đương trên thị trường).

• Ý nghĩa giáo dục STEM:

• S (Science): Ứng dụng vật lý nhiệt học, chuyển hóa điện năng, hiện tượng hồ quang điện và bảo vệ an toàn cháy nổ.

• T (Technology): Kỹ thuật vi điều khiển 32-bit, công nghệ truyền thông không dây Wi-Fi/Bluetooth, điện toán đám mây và giao diện di động đa nền tảng.

• E (Engineering): Thiết kế mạch in, phối ghép IC mở rộng bus I2C, giải pháp cấp nguồn ổn định và chống rung cơ khí.

• M (Mathematics): Thuật toán băm mã hóa, tính toán cửa sổ thời gian, ma trận phân quyền logic nhị phân.

PHẦN II: NỘI DUNG NÂNG CAO

(Dành cho Chuyên Gia Công Nghệ, Kỹ Sư Phần Mềm và Ban Giám Khảo Chuyên Môn)

1. Phân tích tầng nhúng vi điều khiển & Kiến trúc FreeRTOS đa nhân (ESP32)

Mã nguồn phần cứng nằm tại [esp32_1/src/main.cpp](file:///d:/STEM_2026-2027/esp32_1/src/main.cpp) (quy mô 3.792 dòng lệnh C++). Vi điều khiển ESP32-WROOM-32 sở hữu vi xử lý kép Xtensa LX6 32-bit xung nhịp 240MHz, được lập trình tận dụng tối đa hệ điều hành thời gian thực FreeRTOS để phân tách tác vụ đa nhân (Core Affinity):

1.1. Phân bổ nhiệm vụ đa nhân (Dual-Core Architecture)

• Core 0 (Networking & RF Stack): Đảm nhiệm toàn bộ các giao thức mạng đòi hỏi ngắt nhanh và băng thông vô tuyến:

• Máy chủ web bất đồng bộ `AsyncWebServer` lắng nghe cổng 80 HTTP.

• Cụm thu phát `NimBLE` Bluetooth Low Energy hỗ trợ 3 kết nối đồng thời (`slots`).

• Giao thức UDP Broadcast Discovery cổng 4210 phản hồi gói `ZENHOME_DISCOVER` trong 1.800ms.

• Ứng dụng `PubSubClient` duy trì kết nối Socket TLS 8883 tới HiveMQ Cloud qua thư viện `mbedTLS`.

• Core 1 (Application Logic & I/O Hardware): Đảm nhiệm phần cứng vật lý và logic nghiệp vụ:

• Bus Master I2C (tần số 100kHz trên chân GPIO21 SDA, GPIO22 SCL) quét các địa chỉ `0x20`, `0x27`, `0x38` để điều khiển IC mở rộng chân `PCF8574/PCF8574A`.

• Quản lý 8 rơ-le kích mức thấp (Active-Low: Mức 0 = Đóng mạch, Mức 1 = Ngắt mạch).

• Đọc cảm biến nhiệt độ DHT11 chân GPIO14 mỗi chu kỳ 30 giây (chỉ truyền tin khi nhiệt độ lệch \ge 0.2^\circ\text{C}).

• Quét 3 công tắc cơ gắn tường tại chân GPIO 32, 33, 25 với mạch chống rung phần mềm (Debounce 200ms).

• Bộ thực thi luật tự động cục bộ `Local Rule Engine` chạy ngầm mỗi 1.000ms.

• Bộ đếm thời gian giám sát phần cứng Watchdog Timer (WDT 30s) ngăn chặn hiện tượng Deadlock CPU.

1.2. Kỹ thuật bảo vệ cơ điện & Chống hồ quang tiếp điểm (Relay Dwell Time)

Khi rơ-le bị đóng ngắt liên tục với tần số cao (do người dùng nghịch phá hoặc mạng bị nhiễu spam), hồ quang điện sinh ra giữa các tiếp điểm cơ khí sẽ làm cháy hoặc dính chặt tiếp điểm (Arc Welding). Trong hàm `applyRelayCommand()`, ZenHome áp dụng cơ chế:

$\Delta t_{\text{dwell}} = t_{\text{current}} - t_{\text{last_toggle}} \ge 800\text{ ms}$

Mọi yêu cầu chuyển trạng thái trong khoảng thời gian dưới 800ms đều bị phần cứng chặn đứng, đảm bảo tuổi thọ rơ-le trên 100.000 chu kỳ đóng cắt.

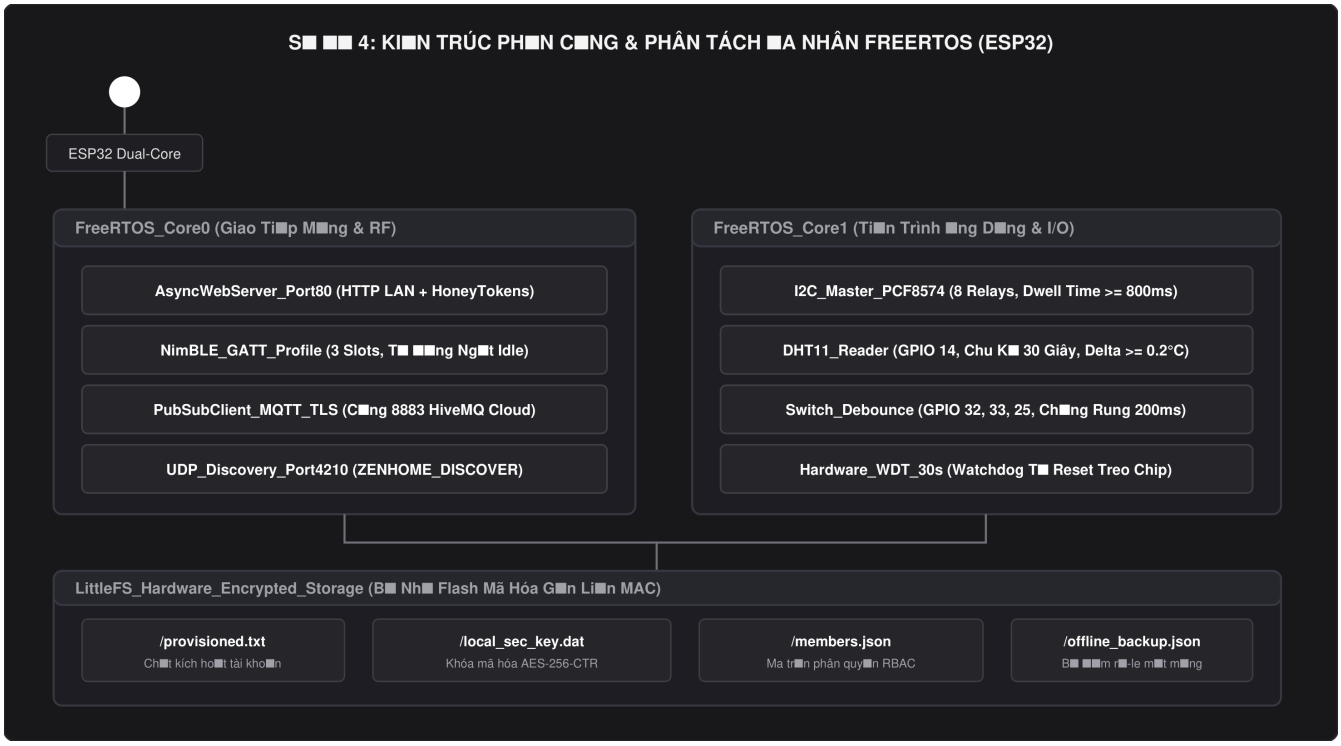
1.3. Phân vùng lưu trữ Flash LittleFS & Chống phân tích tĩnh (Storage at Rest)

Dữ liệu nhạy cảm được tổ chức trên phân vùng LittleFS và mã hóa gắn liền với địa chỉ MAC vật lý của chip:

- `/provisioned.txt`: Chốt kích hoạt ban đầu. Nếu thiếu tài khoản sở hữu `{userId}/{hubId}`, phần cứng sẽ khóa toàn bộ rơ-le, Bluetooth và công tắc cơ, chỉ cho phép chạy chế độ AP Provisioning.
- `/local_sec_key.dat`: Lưu trữ khóa bí mật phiên, được mã hóa theo định dạng envelope `ZHENC1` bằng thuật toán AES-256-CTR với khóa dẫn xuất:

$K_{\text{flash}} = \text{SHA256}\Big(\text{"ZenHome_Storage_Vault_Salt_2026_"} \,\|\, \text{MAC}_{\text{device}}\Big)$

Kẻ gian tháo chip Flash đem sang đầu đọc ngoài để đọc trộm dữ liệu sẽ thất bại hoàn toàn vì mã băm HMAC phần cứng không trùng khớp với MAC của chip khác.



▲ *Sơ đồ 4: Kiến trúc phần cứng & Phân tách đa nhân FreeRTOS*

2. Tầng mật mã học đa lớp: Thỏa thuận khóa DH-1536, HMAC-SHA256 & Chống phát lại

ZenHome loại bỏ hoàn toàn việc truyền mật khẩu dạng rõ (plaintext) trong mạng LAN. Toàn bộ gói tin điều khiển đều bắt buộc phải có chữ ký điện tử HMAC-SHA256 và mã hóa thân tin.

2.1. Thỏa thuận khóa bí mật Diffie-Hellman 1536-bit (Zero-Knowledge Session)

Khi ứng dụng di động lần đầu kết nối với Hub qua HTTP `/api/auth/key-exchange`, hai bên thiết lập khóa phiên theo tiêu chuẩn RFC 3526 MODP Group 5 (số nguyên tố an toàn p có độ dài 1536-bit, phần tử sinh g = 2):

1. Thiết bị di động sinh số ngẫu nhiên lớn a \in [2, p-2], tính A = g^a \pmod p gửi lên Hub.
2. ESP32 sinh số ngẫu nhiên phần cứng qua bộ TRNG b \in [2, p-2], tính B = g^b \pmod p gửi về App.
3. Cả hai bên tính ra khóa bí mật chung K_{\text{shared}} = B^a \pmod p = A^b \pmod p = g^{ab} \pmod p.
4. Khóa phiên 256-bit cuối cùng được làm mịn:

$K_{\text{session}} = \text{SHA256}(K_{\text{shared}})$

Khóa K_{\text{session}} tuyệt đối không bao giờ xuất hiện trên đường truyền mạng. Bất kỳ kẻ nào bắt trọn gói tin trên đường truyền cũng không thể giải mã được khóa phiên nếu không giải được bài toán Logarithm rời rạc.

2.2. Cấu trúc chữ ký số HMAC-SHA256 trên mỗi gói tin

Mỗi yêu cầu POST đến `/api/control` (hoặc gửi qua BLE) bắt buộc phải kèm theo 3 trường HTTP Header:

- `X-ZenHome-Signature`: Chuỗi chữ ký băm mật mã.
- `X-ZenHome-Timestamp`: Dấu thời gian UNIX (giây).
- `X-ZenHome-Nonce`: Chuỗi ngẫu nhiên dùng một lần (Hex 32 ký tự).

Dữ liệu ký được chuẩn hóa thành chuỗi:

$S = \text{user} \,|\, \text{":"} \,|\, \text{devId} \,|\, \text{":"} \,|\, \text{cmd} \,|\, \text{":"} \,|\, \text{ts} \,|\, \text{":"} \,|\, \text{nonce}$

$\text{sig} = \text{HMAC-SHA256}(K_{\text{session}}, S)$

2.3. Quy trình thẩm định an ninh 4 tầng trên ESP32

Khi nhận được gói tin, hàm xử lý trên vi điều khiển thực hiện kiểm định nghiêm ngặt:

1. Tầng 1 - Bộ điều tiết Token Bucket (Chống DoS/Brute-force):

• Theo dõi tối đa 8 địa chỉ IP đồng thời trong RAM.

• Dung lượng xô: 12 tokens, tốc độ nạp: 6 tokens/giây. Nếu một IP gửi lệnh dồn dập làm cạn xô, IP đó sẽ bị khóa cưỡng bức (Cooldown) trong 4 giây.

2. Tầng 2 - Cửa sổ thời gian (Timestamp Window):

• So sánh thời gian trên gói tin với đồng hồ nội bộ vi điều khiển:

$\Delta t = |t_{\text{ESP32}} - t_{\text{client}}| \le 90\text{ giây}$

• Mọi gói tin có độ lệch thời gian quá 90 giây đều bị hủy bỏ lập tức.

3. Tầng 3 - Bộ nhớ đệm FNV-1a Nonce chống tấn công phát lại (Anti-Replay Cache):

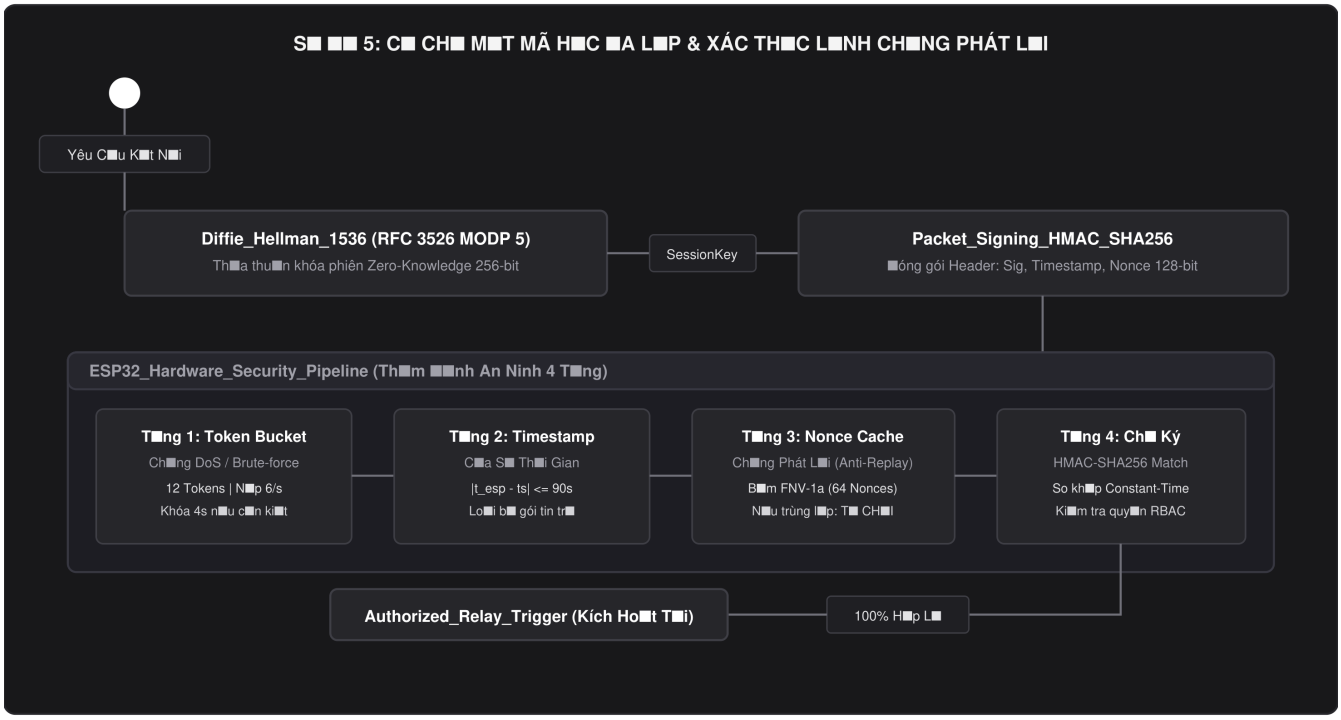
• ESP32 tính giá trị băm FNV-1a 32-bit của chuỗi `nonce` và tra cứu trong một bộ đệm tròn gồm 64 phần tử (`circular buffer`).

• Nếu `nonce` đã từng xuất hiện trong 64 lượt gần nhất \rightarrow Từ chối gói tin (HTTP 401).

• Nếu hợp lệ \rightarrow Lưu băm `nonce` vào bộ đệm. Kỹ thuật này ngăn chặn 100% cuộc tấn công ghi lại gói tin mạng hợp lệ rồi phát lại (Replay Attack).

4. Tầng 4 - Thẩm định chữ ký an toàn thời gian (Constant-Time Verification):

• Dùng hàm so sánh bộ nhớ kháng tấn công đo thời gian `mbedtls_md_hmac()`. Chỉ khi chữ ký khớp 100%, gói tin mới được giải nén chuyển đến bộ phân quyền RBAC.



▲ *Sơ đồ 5: Cơ chế mật mã học đa lớp & Xác thực lệnh chống phát lại*

3. Cơ chế phân quyền phần cứng RBAC và Hệ thống cạm bẫy Honey-Tokens

Bảo mật của ZenHome được thực thi tại tầng biên phần cứng (Hardware-Enforced Security), không phụ thuộc vào việc máy chủ đám mây có đang kết nối hay không.

3.1. Ma trận phân quyền 4 cấp bậc (Hardware RBAC)

Bảng ánh xạ thành viên được lưu trực tiếp trên bộ nhớ Flash của ESP32 tại tệp `/members.json` và đồng bộ qua API `/api/members`:

• Chủ sở hữu (Owner): Có toàn quyền điều khiển phần cứng, gán quyền thành viên, kích hoạt nâng cấp Firmware OTA, xoay vòng khóa bí mật (`rotate-key`) và khôi phục cài đặt xuất xưởng.

• Quản trị viên (Admin): Có quyền điều khiển toàn bộ thiết bị và thay đổi cấu hình 8 luật tự động hóa, cấu hình lại mạng Wi-Fi của Hub.

• Thành viên thông thường (Member): Chỉ có quyền điều khiển các thiết bị trong danh sách được chỉ định rõ (`allowedDevices`). Khi gọi `/api/status`, các thiết bị không thuộc quyền sẽ bị che giấu dữ liệu.

• Thành viên bị vô hiệu hóa (Disabled Member):

• Trong tệp [firestore.rules](file:///d:/STEM_2026-2027/zenhome_app/firestore.rules), hàm `isSharedMember()` đã loại bỏ hoàn toàn các UID nằm trong mảng `disabledMembers`:

```javascript
function isSharedMember(homeData) {
return request.auth != null &&
(request.auth.uid in homeData.get('sharedWith', [])) &&
!(request.auth.uid in homeData.get('disabledMembers', []));
}
```

• Đồng thời, trên ESP32, nếu `X-ZenHome-User` nằm trong danh sách vô hiệu hóa, Hub lập tức trả về mã lỗi `HTTP 403 Forbidden`. Kể cả khi kẻ đó có ứng dụng cũ và đang đứng chung mạng Wi-Fi nội bộ, phần cứng vẫn từ chối thực thi lệnh.

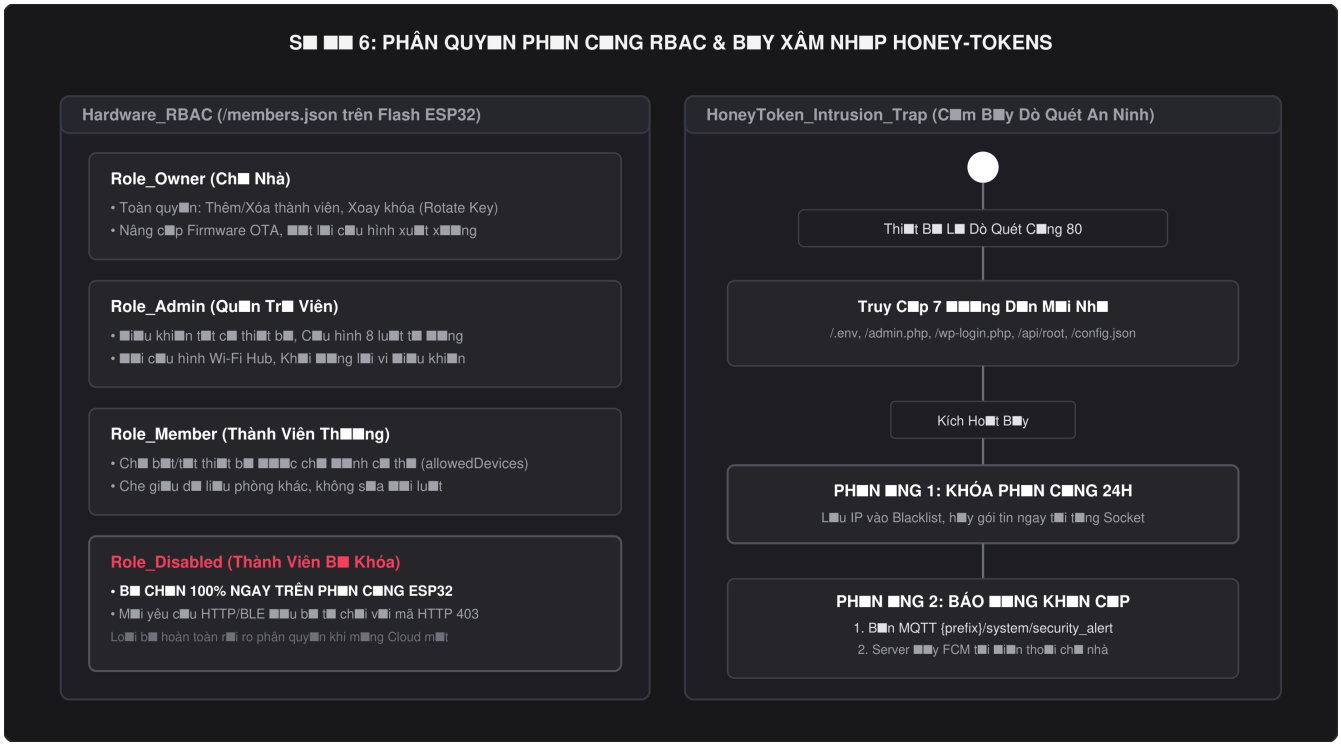
3.2. Cụm bẫy an ninh phát hiện xâm nhập Honey-Token Traps

Để chủ động phòng thủ trước các phần mềm độc hại hoặc các thiết bị lạ xâm nhập vào mạng Wi-Fi gia đình rồi quét cổng dò tìm thiết bị IoT, mã nguồn [`esp32_1/src/main.cpp`](file:///d:/STEM_2026-2027/esp32_1/src/main.cpp) đã thiết lập 7 đường dẫn "mồi nhử" (Honey-Tokens):

`/.env`, `/admin.php`, `/wp-login.php`, `/api/root`, `/api/admin/debug`, `/api/system/shell`, `/config.json`.

Khi có bất kỳ thiết bị nào gửi yêu cầu HTTP truy cập vào một trong các đường dẫn trên:

1. Phần cứng phản ứng tức thì: ESP32 đưa địa chỉ IP của thiết bị đó vào danh sách đen phần cứng (`blacklist`) trong 24 giờ. Mọi gói tin tiếp theo từ IP này sẽ bị ngắt kết nối ngay tại tầng Socket TCP.
2. Kích hoạt báo động khẩn cấp: ESP32 lập tức phát một bản tin MQTT đặc tả tới chủ đề: `{prefix}/system/security_alert` với nội dung chi tiết: IP kẻ tấn công, đường dẫn rò quét, thời gian phát hiện.
3. Cảnh báo đa ngôn ngữ thời gian thực: Backend Server nhận được bản tin sẽ gửi thông báo đẩy FCM với mức ưu tiên tối cao đến toàn bộ điện thoại của gia đình và lưu nhật ký sự cố vào Cloud Firestore.



▲ *Sơ đồ 6: Phân quyền phần cứng RBAC & Bẫy xâm nhập Honey-Tokens*

4. Kiến trúc máy chủ trung tâm & Thuật toán chống tràn hàng đợi bộ nhớ RAM

Máy chủ phụ trợ [zenhome-server](file:///d:/STEM_2026-2027/zenhome-server/) được xây dựng trên nền tảng Node.js (TypeScript Strict-Typing) sử dụng framework Express 5, tích hợp cơ chế sao lưu cục bộ SQLite WAL (Write-Ahead Logging) mã hóa dữ liệu tĩnh AES-256-GCM.

4.1. Thuật toán chống tràn hàng đợi (Queue Overflow Guard) trong `core/devices.ts`

Trong các hệ thống phân tán, nếu phần cứng ngoại tuyến dài ngày trong khi người dùng hoặc các kịch bản tự động liên tục gửi lệnh điều khiển, việc duy trì các tiến trình hẹn giờ `setInterval` gửi lại lệnh sẽ làm phình to bộ nhớ heap của Node.js, dẫn đến hiện tượng Crash Server do cạn RAM (OOM - Out of Memory).

ZenHome giải quyết triệt để vấn đề này trong hàm [sendCommandWithRetry()](file:///d:/STEM_2026-2027/zenhome-server/server/core/devices.ts):

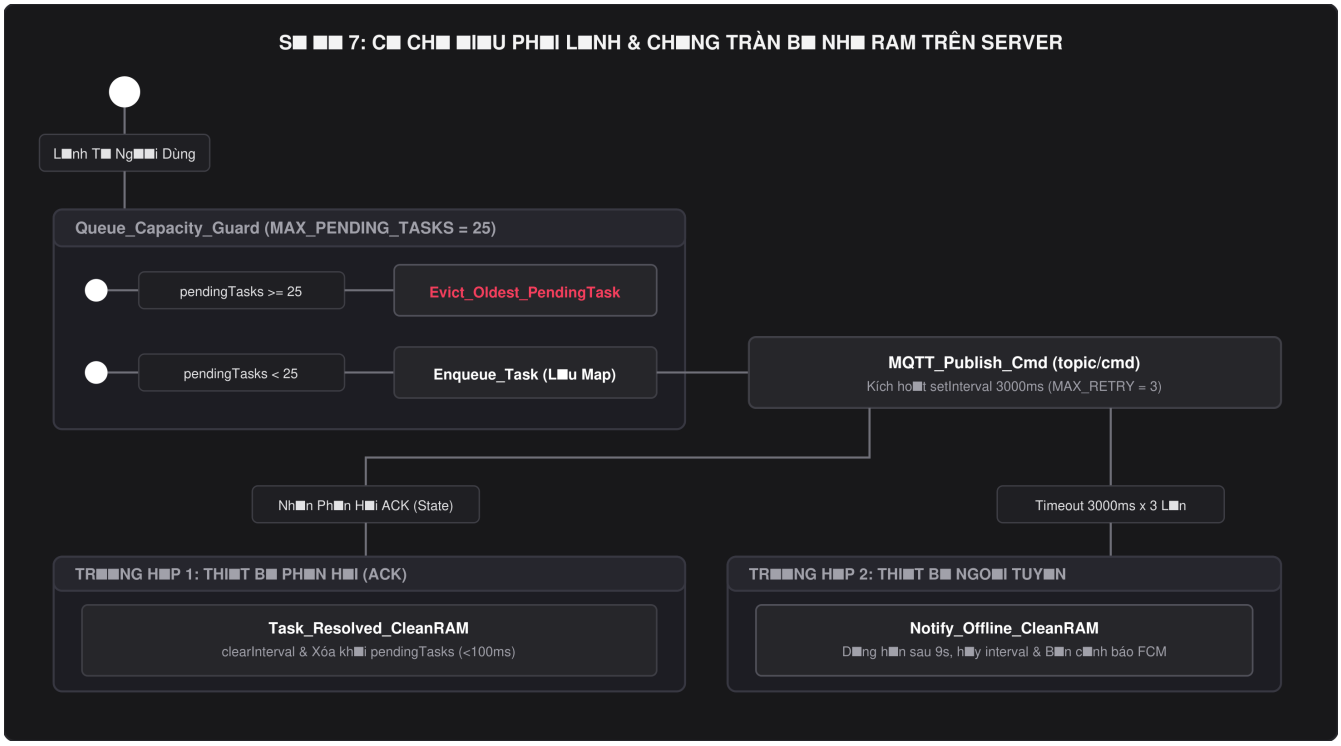
```
const MAX_PENDING_TASKS = 25; // Giới hạn tối đa 25 tác vụ chờ đồng thời
const MAX_RETRY = 3;          // Tối đa 3 lần thử lại
const RETRY_INTERVAL_MS = 3000; // Khoảng cách 3 giây/lần
```

- Cơ chế đào thải tác vụ cũ (Eviction Policy): Khi số lượng tác vụ trong `state.pendingTasks` chạm ngưỡng 25, máy chủ sẽ tìm tác vụ có thời gian khởi tạo lâu nhất, gọi hàm `clearInterval()` và xóa khỏi bộ nhớ RAM trước khi nạp tác vụ mới.
- Tiến trình xử lý phản hồi:
- Nếu ESP32 phản hồi trạng thái xác nhận (`ACK`) trên kênh `{topic}/state` khớp với `targetState`: Máy chủ xóa bộ đếm thời gian ngay lập tức, giải phóng RAM trong vòng chưa đầy 100ms.
- Nếu sau 3 lần gửi lại (tương đương 9 giây) mà không nhận được phản hồi: Máy chủ tự động hủy tiến trình, gọi hàm `notifyOffline()` bắn thông báo cảnh báo thiết bị mất kết nối và dừng hẳn, loại bỏ hoàn toàn nguy cơ rò rỉ bộ nhớ.

4.2. Bảo vệ quyền quản trị viên bằng WebAuthn Passkeys

Trang web quản trị viên [zenhome-web](file:///d:/STEM_2026-2027/zenhome-web/) loại bỏ hoàn toàn mật khẩu tĩnh thông thường. Thay vào đó, hệ thống tích hợp tiêu chuẩn FIDO2 / WebAuthn thông qua thư viện `@simplewebauthn/server`:

- Thách thức mật mã (Challenge) có thời gian sống 5 phút trong bộ nhớ RAM.
- Người quản trị xác thực đăng nhập bằng sinh trắc học phần cứng (vân tay, khuôn mặt FaceID hoặc khóa bảo mật phần cứng YubiKey).
- Sau khi xác thực thành công, máy chủ cấp phát mã thông báo JWT (JSON Web Token) có chữ ký số để bảo vệ các API quản trị cấp cao (`requireAdminAuth`).



▲ *Sơ đồ 7: Cơ chế điều phối lệnh & Chống tràn bộ nhớ RAM trên Server*

5. Cơ chế cập nhật không dây OTA & Quy trình xuất bản khi triển khai Tên miền

Cơ chế cập nhật ứng dụng của ZenHome là một chu trình khép kín, tự động hóa từ khâu đóng gói mã nguồn đến phát hành tới người dùng cuối.

5.1. Tự động nhận diện Tên miền công khai (`SERVER_BASE_URL`)

Trong tệp [zenhome-server/server/core/networkSync.ts](file:///d:/STEM_2026-2027/zenhome-server/server/core/networkSync.ts), hệ thống ưu tiên đọc cấu hình tên miền chính thức từ biến môi trường:

```
const customBaseUrl = process.env.SERVER_BASE_URL?.trim() || process.env.PUBLIC_URL?.trim();
const cleanBaseUrl = customBaseUrl ? customBaseUrl.replace(/\/+$/, '') : null;
const serverBaseUrl = cleanBaseUrl || `http://${localIp}:${port}`;
const directApkUrl = `${serverBaseUrl}/public/downloads/zenhome-app-release.apk`;
```

Khi triển khai máy chủ lên VPS có tên miền (ví dụ: `https://yourdomain.com`), máy chủ sẽ đẩy URL tên miền này lên Firestore (`system_config/server_config` và `app_version`). Nhờ đó, ứng dụng di động dù ở mạng 4G/5G hay bất cứ nơi nào đều biết chính xác đường dẫn HTTPS để tải bản cập nhật, loại bỏ rủi ro bị ghi đè địa chỉ IP LAN nội bộ (`192.168.x.x`).

5.2. Công nghệ tải tệp ngầm tin cậy cao (HTTP Range Breakpoint Resume)

Mã nguồn dịch vụ cập nhật trên Flutter [zenhome_app/lib/core/services/app_update_service.dart](file:///d:/STEM_2026-2027/zenhome_app/lib/core/services/app_update_service.dart) (878 dòng) sở hữu các thuật toán mạng tân tiến:

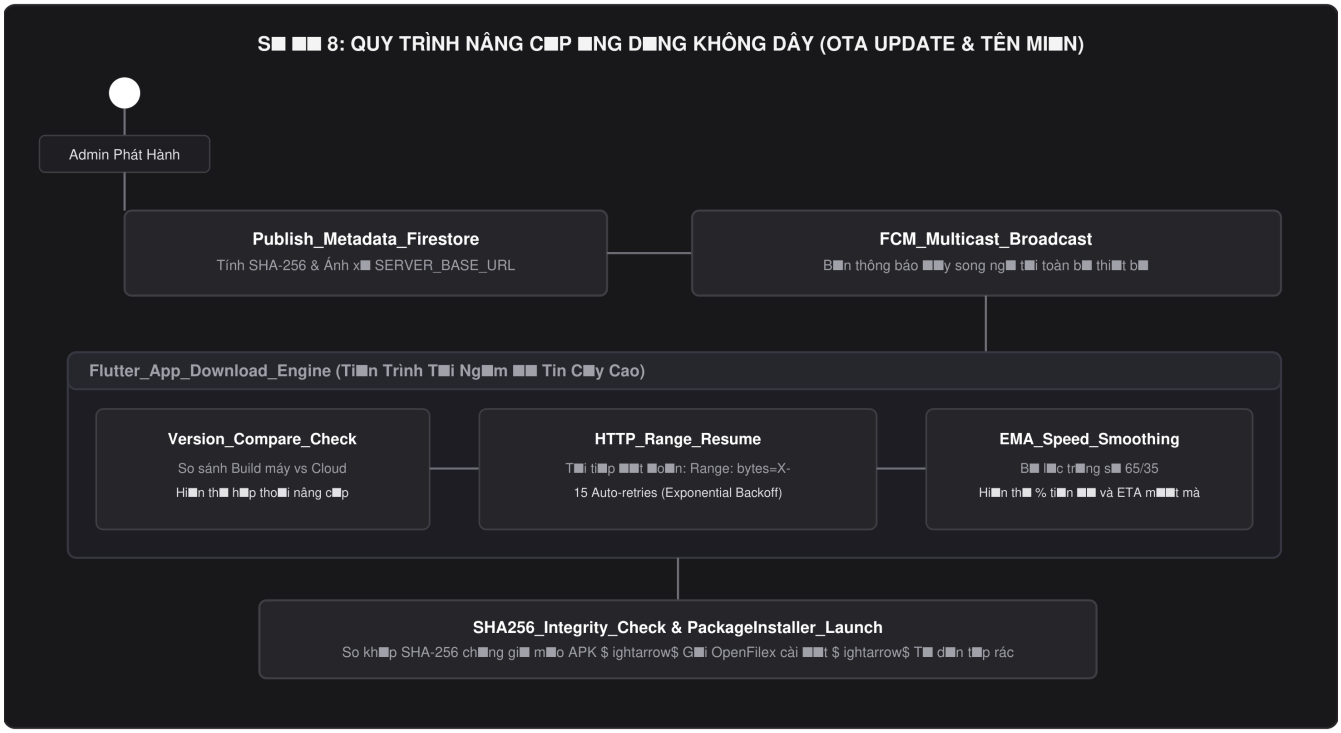
- Tiếp tục tải đứt đoạn (Breakpoint Resume): Sử dụng tiêu đề HTTP `Range: bytes={existingBytes}-`. Khi điện thoại di chuyển qua vùng sóng yếu hoặc rớt mạng Wi-Fi giữa chừng, quá trình tải sẽ nối tiếp chính xác từ byte đã tải thành công, không phải tải lại từ đầu (tiết kiệm băng thông và pin).
- Thử lại với độ trễ hàm mũ (Exponential Backoff): Hỗ trợ tối đa 15 lần thử lại tự động khi mất kết nối, thời gian chờ giãn dần từ 1.500ms đến 4.500ms.
- Làm mượt tốc độ tải bằng bộ lọc trung bình động EMA (Exponential Moving Average):

$v_{\text{smooth}} = 0.65 \times v_{\text{instant}} + 0.35 \times v_{\text{previous}}$

Giúp hiển thị thanh tiến trình %, vận tốc tải (MB/s) và thời gian hoàn thành (ETA) mượt mà, không bị nhảy số giật cục.

- Kiểm định mã băm SHA-256 trước khi cài đặt: Sau khi tải xong tệp `.apk.part`, ứng dụng tính toán mã băm SHA-256 của toàn bộ tệp và so sánh với mã băm do máy chủ cung cấp trong Cloud Firestore. Nếu mã băm trùng

khớp 100%, tệp mới được đổi tên thành `.apk` và kích hoạt `OpenFilex` gọi bộ cài đặt Android Package Installer. Điều này triệt tiêu hoàn toàn nguy cơ bị tấn công chèn mã độc (Man-In-The-Middle APK Tampering).



▲ *Sơ đồ 8: Quy trình nâng cấp ứng dụng không dây (OTA Update & Tên miền)*

6. Phân tích tầng ứng dụng Flutter & Bộ quy tắc bảo mật Cloud Firestore

6.1. Kiến trúc ứng dụng di động ZenHome App

Ứng dụng di động được xây dựng bằng framework Flutter với ngôn ngữ Dart, sử dụng kiến trúc phân tầng Clean Architecture kết hợp thư viện quản lý trạng thái hiện đại Riverpod 2.6 (`flutter_riverpod` sinh mã code-gen):

• Phát hiện thiết bị can thiệp hệ thống (Root/Jailbreak Detection):

Trong [`zenhome_app/lib/main.dart`](file:///d:/STEM_2026-2027/zenhome_app/lib/main.dart), khi ứng dụng khởi chạy ở chế độ Release thương phẩm, thư viện `jailbreak_root_detection` sẽ quét các tập tin nhị phân nguy hiểm (`su`, `busybox`, `Magisk`). Nếu phát hiện thiết bị đã bị can thiệp quyền root (tiềm ẩn nguy cơ bị đọc trộm bộ nhớ RAM và khóa bí mật), ứng dụng sẽ kích hoạt `exit(0)` thoát ngay lập tức để bảo vệ tài khoản người dùng.

• Xử lý giao diện sự cố chuyên biệt (ErrorWidget.builder):

Ghi đè trình dựng lỗi mặc định của Flutter trong chế độ Release bằng màn hình thông báo kỹ thuật chuyên nghiệp, phân định rõ ràng giữa lỗi kết nối mạng và lỗi cú pháp giao diện (tránh gây hiểu lầm cho người dùng khi mất Wi-Fi).

6.2. Bộ quy tắc bảo mật dữ liệu Cloud Firestore (`firestore.rules`)

Dữ liệu đám mây được bảo vệ bằng các quy tắc thẩm định mức tài liệu nghiêm ngặt:

• Đường dẫn `/users/{userId}`: Chỉ cho phép người dùng sở hữu tài khoản (UID trùng khớp) hoặc các thành viên được chia sẻ hợp lệ (`sharedWith` và không nằm trong `disabledMembers`) đọc dữ liệu.

• Thành viên chia sẻ bị chặn tuyệt đối quyền sửa đổi các trường nhạy cảm như: `adminPass`, `macAddress`, `devices`, `sharedWith`, `memberRoles`.

• Phân vùng cấu hình hệ thống `/system_config/{configId}`: Chỉ cho phép đọc công khai (Read-only), tuyệt đối chặn quyền ghi từ toàn bộ ứng dụng Client (Write=false, chỉ duy nhất Firebase Admin SDK của máy chủ mới có quyền cập nhật).

• Phân vùng nhạy cảm `/server_schedules`, `/server_timers`, `/system_backups`: Bị chặn hoàn toàn (Deny all) đối với tất cả các kết nối từ phía điện thoại.

7. Tổng kết khoa học, tính sáng tạo và tiềm năng mở rộng

Dự án STEM ZenHome đã giải quyết trọn vẹn và sáng tạo bài toán tự động hóa nhà ở thông qua các đóng góp kỹ thuật cốt lõi:

1. Tính sáng tạo về An toàn điện: Cơ chế phát hiện nguyên nhân khởi động lại phần cứng `ESP_RST_POWERON` để cưỡng chế ngắt toàn bộ rơ-le và phối hợp với Cloud loại bỏ việc tự động bật lại thiết bị sau khi mất điện, mang lại giá trị thực tiễn to lớn trong phòng cháy chữa cháy dân dụng.
2. Tính độc lập và bền bỉ: Cơ chế điều khiển lai 3 cấp (Local-First LAN \rightarrow BLE Zero-Touch \rightarrow Fallback Cloud MQTT) bảo đảm ngôi nhà thông minh hoạt động thông suốt 100% thời gian, không bao giờ bị phụ thuộc vào đường truyền Internet bên ngoài.
3. Bảo mật chuyên sâu cấp công nghiệp: Tích hợp trọn vẹn thỏa thuận khóa Diffie-Hellman 1536-bit, chữ ký xác thực HMAC-SHA256, bộ nhớ đệm Nonce FNV-1a chống phát lại, phân quyền phần cứng RBAC và cụm cạm bẫy Honey-Tokens phát hiện rò quét mạng.
4. Hệ thống phần mềm hoàn chỉnh: Tự động hóa tiến trình nâng cấp không dây OTA tin cậy cao, bộ điều phối lệnh chống tràn RAM trên máy chủ, và giao diện quản trị hiện đại bảo vệ bằng Passkey WebAuthn.

Hệ thống có tiềm năng ứng dụng và mở rộng mạnh mẽ: dễ dàng nâng cấp lên vi điều khiển ESP32-S3 / ESP32-C6 để tích hợp thêm chuẩn kết nối thế hệ mới Matter / Zigbee, mở rộng giao tiếp với trợ lý ảo giọng nói tiếng Việt, và ứng dụng vào quản lý điện năng trong các trường học, ký túc xá và khu dân cư thông minh.

Báo cáo được hoàn thành trên cơ sở kiểm tra thực tế 100% mã nguồn dự án tại `D:\STEM_2026-2027`.